

lable features for SSO and automated user management.

- How should user creation, updates, and deactivation be processed?
- Which groups of users need access to this? An exact list of existing Google groups or a list of users will be needed.
- Timeline: Please allow up to 4 weeks for an application integration to be completed. If the request is urgent, please tag your manager and explain the urgency and requested date of completion.

How do I request an app to be updated?

First, please open a CorpSec Issue and tag @gitlab-com/gl-security/corp/identity for Iteration planning and specification gathering. Application Update Requests are tracked via a Change Management Issue within the Business Technology team. Please use the `oktaexistingappupdate` template to ensure all required information fields are inputted.

How can I change the order in which my apps appear?

To change the order of your apps, click and hold on an app icon, then drag and drop the app to the location you would like it to be displayed.

How do I move an app from one tab to another?

To move an app from one tab to another, click and hold on the app icon, then drag and drop your app to the new tab.

How do I remove an app?

Apps you've installed can be removed by hovering over the app and selecting the gear icon. In the app setting screen, you'll see the option to delete it. Apps issued by the GitLab Okta administrator cannot be removed, but there is a way to move the app out of sight. The best way to do so is to create a new tab to store unused and unwanted applications.

What is a bookmark?

A bookmark is a way to save the URL login of an app not currently available to you. When you create a new bookmark, your Okta dashboard will display an app icon to that app URL login. This bookmark will only store the URL, not your username and password.

How do I add a bookmark?

To add a bookmark, go to the "+Add Apps" button on the top right of your dashboard to open a search menu. Search for your app. If no app is found, Okta will display the option to create a bookmark. Enter the URL of the app and the name of the bookmark you would like displayed. Click 'Add' button to create your bookmark. Click on "Home" at the top of your dashboard to see your new bookmark.

How do I Search an app if I can't remember which tab I put it on?

At the top of your dashboard, you can find apps in the "Launch App" search bar. If you can't remember which tab your app is on, go to the Launch App search, type in the name of your app

and select the name to open it when it appears.

Does Okta store our information entered into apps?

No, Okta only acts as an integrator to the various apps. The information that the user stores inside of the app, is not accessible by Okta. The usernames and passwords (user credentials) are encrypted using both an industry--standard encrypted AES and a randomly generated symmetric key.

What's the difference between SWA and SAML?

SWA - A SWA integration provides single sign-on for apps that don't support proprietary federated sign-on methods; it works with any web-based app. If your SWA app integration is successful, the following happens when end-users click the app chicket:

- The username and password fields are populated.
- Users are signed in to the app automatically.

SAML - A SAML (Security Assertion Markup Language) integration provides Federated Authentication standards that allow end users one-click access to the app.

SAML is an XML-based standard for exchanging authentication and authorization data between an identity provider (IdP) such as Okta, and a service provider (SP).

If your Application supports SAML, then this is a better Authentication Protocol over SWA. When SAML is enabled Okta will be the Authentication provider for the application, also, this Authentication Protocol will give you more control over your users Authentication behavior. Okta can authenticate to Cloud Applications using SAML Assertions, a "passwordless" assertion method that is authorised based on a trust decision from Okta based on its authentication policy. This reduces the exposure for credential leakage and eases auditability.

How do self-service applications work with Okta?

There is an example of this in the Application configuration Video linked on the Okta page. In short, click on the Add Apps button, search for the App you want to request, and click the request button. As a best practice, link in the Access Request issue created so that the Application owner understands the requirements of the request!

Can the apps be renamed or append their function?

Yes, we can add App Notes to each of the Apps, and will work through them to add intuitive labels. For an example, we have already enabled this on Workday and a few others. To configure Apps and improve your user experience, please see the Dashboard Tips video on the Okta main page.

Is there a reason why my Application is not integrated via SAML2.0?

There are applications that may need conversion to SAML. Please open a Change Management Issue to request the update.

What is my username and password for GitLab Okta?

At GitLab, your GitLab email address is your username. If you've forgotten your password, please reach out in [ithelp](#).

How do I make a safe password?

Okta supports strong passwords through the use of password complexity rules and length, consistent with our password policy. Please follow GitLab's Password Policy guidelines to determine the rules.

How does Multi-factor Authentication (MFA) work?

Your user credentials are encrypted using both an industry-standard encrypted AES and a randomly generated symmetric key. This key-store, containing your symmetric encryption keys, is then encrypted with a master key that is held only in memory and only accessible to the Okta app. At startup, the app is provided a master passphrase allowing it to access, decrypt, and store the master key in memory. A technical operations administrator at your company inputs the master passphrase. Only a select number of administrators know this master passphrase. As a result, attackers can only decrypt the data if they have the master key, private key, as well as the user's app context.

Why do I have to input my password for some apps and not others?

With Okta you can access your applications through a single, unified dashboard. Access to these applications is delivered through single sign-on (SSO) technology via either Security Assertion Markup Language (SAML) or Okta's Secure Web Authentication (SWA) technology.

With SWA, you may need to enter your username and password upon the first use of that application. If an app requires you to make a password change, you should do so within the Okta dashboard. With SAML, Okta automatically passes on access via a token, so you don't need to manually make a change when the app requires an update.

How do I change my password for an app?

To change your password for a specific application, hover your mouse over the app's icon. Click the gear to go to settings, which should open a menu that gives you the option to change your password for that specific application.

If you are not able to update the username and password, contact GitLab Okta support or the IT Ops team.

Can I be confident my password is safe?

Yes, nobody (including GitLab administrators or IT support) have access or visibility into your password data.

Where & how is my username and password stored?

Okta uses strong encryption to secure data and uses strong (256-bit AES) encryption for username and password credentials. This information is stored and maintained by Okta.

How long does my login last until I need to re-authenticate?

Okta has two controlled re-authentication parameters -- Factor Lifetime and Session Lifetime.

Factor Lifetime: Setting a factor lifetime is a way for end users to sign out for the amount of time noted in the Factor Lifetime and not have to authenticate again with MFA at the next sign in. End users must check a box to confirm that the setting should be applied. We have configured this to be 15 minutes. If you are logging on with a machine that isn't your usual device, make sure you don't check this button!

Session Lifetime: The maximum idle time before an authentication prompt is triggered. We have configured this to be 4 hrs.

If you are having issues with excessive authentication requests, please log an issue and we will investigate.

Can my GitLab Okta admin see my login information?

The GitLab administrator can see your username, but he or she does not have access to your password or any other credentials or devices you use to authenticate.

Will Okta support our password policy?

Yes, Okta has been configured such that - it adheres to the GitLab password policy and restrictions.

Any app that is already integrated and existing in Okta can be deleted from 1Password?

Yes, once you've put the credentials in Okta, you may delete it from 1password.

Is it acceptable to continue using Google OAuth login for some of the apps (with its own 2FA)?

Yes, this is fine. Our end state will be to use Okta for most/all applications, but in the meantime existing authentication methods are fine. Once we have broader user adoption of Okta, we'll be taking on migration of some of these apps to use Okta instead of Google OAuth, where this makes the most sense.

Will Okta only be used for work-related credentials? If so, how will it be enforced?

At this time there is nothing stopping someone from using personal credentials. See the video created about configuring Apps for more details.

Does Okta have any visibility into MFA?

MFA is strictly enforced on Okta. This acts as a gateway to the services it manages. So those services, in effect require MFA via Okta login.

Will Okta be used to prevent logins from particular devices or conditions?

Yes, via Okta Device Trust and IP-based controls based on threat intelligence feeds.

Why does my Okta session expire but some of the apps are still open?

Okta does not log you out of your applications even though you might be logged out of your Okta session.

What happens if Okta goes down?

Okta is built on an "Always On" architecture. However, if their services were to go down, you would not be able to log in to your GitLab Okta platform and access your applications via Single Sign-On. However, some applications might still be accessible through a direct link. When Okta is down, basically GitLab will be down. Any mitigation strategy would enlarge our security surface area.

What is our policy if Okta is down? Should employees wait or is there a backup plan?

When Okta is down, we are down. Any mitigation strategy would enlarge our security surface area.

Okta is built on an "Always On" architecture. However, if their services were to go down, you would not be able to log in to your GitLab Okta platform and access your applications via Single Sign-On. However, some applications might still be accessible through a direct link.

Who do I contact in case of Okta emergencies?

Please reach out to ithelp channel on Slack.

Is there any automated reporting?

No, this does not exist within Okta. But this should be something security automation team can help with. There are some automated security notifications already enabled for things like MFA or password changes, as well as connections from new and unrecognised devices. GitLab is able to perform reporting on these based on built-in reporting.

What are some things Okta won't be able to do yet?

Automating access requests is one such thing. Manager approval is not possible with Okta as yet. We are working towards other ways and means to achieve this.

Does Okta integrate with a VPN provider that allows all team members to use a company-wide VPN?

There is capacity to do this, but further research is needed to understand the application use case for this. At this stage, requirement for VPN is not enabled.

For those who used a GitLab personal account when onboarded, what happens at offboarding?

For users who started prior to 2020-03-23, they are removed from GitLab groups. When offboarding happens, your Okta account and related accounts are deactivated.

SECTION: security/corporate/end-user-services/onboarding-access-requests/_index.md

See Access Requests

SECTION: security/corporate/end-user-services/onboarding-access-requests/access-requests/_index.md

Access Requests are owned by the IT team, while onboarding, offboarding and internal transition requests are owned by the People Connect Team.

If you have any access requests related questions, please reach out to ithelp or the tool provisioner in Slack.

Access requests related pages

- Frequently asked questions
- Baseline Entitlements
- Temporary service providers access requests and onboarding

Need help?

- Please @ mention @gitlab-com/gl-security/corp/helpdesk in the issue, with no particular SLA.
- If your request is urgent, @ mention it-helpin the ithelp channel in slack with a note on why it is urgent.

How do I choose which template to use?

Individual or Bulk Access Request

You can use this template to request access for individuals or multiple people, as long as all the people are requesting access to the same systems. Create multiple issues using this same template if multiple people require access to different systems. When access is being requested for multiple people who report to different managers but are part of the same department or division, approval can be obtained by the manager at the highest level; that is, the Director, Vice President, or Executive of the department or division.

{{% panel header="Instructions" header-bg="success" %}}

Title the issue Full Name, System(s), Role using the details of the person requesting access information. If bulk access is being requested then Bulk Access, System(s), Role

Step 1. Personal Information

1. Personal Information: Please provide a list of people who are requesting access. Include the relevant information.
1. SSH Keys: Add the public ssh key only if needed for the type of access being requested.

Step 2. Access Request

1. Remove or add lines for the systems you need access to. Make sure to follow the format from the template (also included below). Be as specific as possible with the access you are

requesting by adding the role, vault, group, channel or project you are requesting access to.

1. If administrative access is being granted, add the label admin-access. Request the least amount of access you need as per the least privilege review and explain why you need access in the rationale section.

1. If the request involves access to systems owned by the Infrastructure team (according to the tech stack, mention @gitlab-com/gl-infra/managers and ask them to approve by adding the ~InfrastructureApproved label.

text

- [] System name: Which vault, which group, which channel, which project, which role?
- Justification for this access: Please explain why this access is needed.

Step 3: Assign to Manager for approval

1. If you are a manager requesting access for one of your reports, please skip to step 4.

1. Add the label AR-Approval::Needs Manager Approval to the issue.

1. Assign the issue to your manager. When access is being requested for multiple people who report to different managers but are part of the same department or division, approval can be obtained by the manager at the highest level; that is, the Director, Vice President, or Executive of the department or division.

Step 4: Managers to do

1. If you are the manager of this person, add the labels AR-Approval::Manager Approved and ReadyForProvisioning to the issue; if you are the one asking for access, then you have to assign to your manager for approval and they must add the labels AR-Approval::Manager Approved and ready for provisioning.

1. After approval, then YOU MUST assign the issue to the system provisioner listed in the tech stack.

Step 5: Provisioners to do

1. Before provisioning, consider that team members should only be granted the minimum necessary access to perform their function. Determine whether the access level is necessary or if a lower access level would be sufficient.

1. If the access level is adequate proceed with provisioning the account after verifying the AR-Approval::Manager Approved label is present.

1. Under step 2, please check off the system you provisioned.

1. If administrative access is being granted, add the label admin-access to this request so Security Operations knows who has admin access.

- If admin access is being granted to GitLab.com ensure the user is added to the GitLab Instance Administrators group

- Inform the user 2fa is required and they will be locked out if it is not immediately setup {{% /panel %}}

Access Change Request

Access Change Requests are logged when a team member no longer requires access to a currently provisioned system or no longer requires the same level of access (downgraded access from admin to user etc).

Refer to For Total Rewards Analysts: Processing Promotions & Compensation Changes section of the GitLab handbook for additional information.

It is important to note that while Okta has provisioning/deprovisioning automation in place, this is not a complete/accurate reflection of access provisioning and deprovisioning.

Okta has been configured to assign integrated/implemented applications based on a user's role/group.

This makes applications accessible via Okta but users may still have the ability to access the systems directly.

Refer to Okta Application Stack for a list of applications set up in Okta.

What this means is:

1. A GitLab Team member gets transferred to a different role.
1. The team member's profile in Workday is changed.
1. This profile change automatically triggers a change in the team member's Okta profile accordingly.
1. This, in turn, results in the team member getting assigned to new applications based on their new department and role.
1. Simultaneously all old applications that are not relevant to their new role get revoked/unassigned.
1. Additionally, the Okta administrator gets an Email from Okta, that there has been a change to a User profile - (Email Subject line: 1 existing user updated). Okta automation already happens in the background, this email is informational only.

While this application automation will take place in Okta, "true" system provisioning and deprovisioning will still need to be manually completed within the impacted systems via an Access Change Request.

Name Change Request

You can use this template when your name changes.

{{% panel header="Instructions" header-bg="success" %}}

1. Title the issue Full Previous Name to Full New Name - Name Change Request.

1. Please complete all applicable sections as described in the issue template.

{{% /panel %}}

Working on Access Requests

Department Access Request Boards

- If you need additional labels or have suggestions for improving the process until we can fully automate, please open an issue.
- ARs are auto-assigned and auto-labeled when possible by department. In some cases, there are multiple provisioners per tool. If a template cannot be auto-assigned, Business Technology will provide a board where the provisioners can review their department's issues by label (ie dept::to do. It is up to the department to manage the workflow on who works the issues to completion.
- Moving an issue from one column to another will remove the first label (per the column header) and add the second label. Please use caution when moving issues between columns.
- Departments can check their outstanding access request issues by viewing their board below.

{{% panel header="AR boards: to-do:" header-bg="success" %}}

- 1. Data
 - 1. Finance
 - 1. Infra
 - 1. IT
 - 1. Legal
 - 1. PeopleOPs
 - 1. Prod+Eng
 - 1. Marketing
 - 1. Sales
 - 1. Security
 - 1. Support
- {{% /panel %}}

Adding Access Request Process for a new item in the Tech Stack

If you need to initiate an Access Request process for a new item in the tech stack:

- 1. Confirm the tool is added to the tech stack
- 1. Confirm a team member is included as the provisioner deprovisioner
- 1. Document the requirement to submit an Access Request in any relevant handbook pages

SECTION: security/corporate/end-user-services/onboarding-access-requests/access-requests/frequently-asked-questions.md

Need help?

- Please @ mention @gitlab-com/business-technology/end-user-services in the issue, with no particular SLA.
- If your request is urgent, @ mention it-helpin the ithelp channel in slack with a note on why it is urgent.

I need access

My AR request has been open for a while, how can I get traction on it?

1. Review that the access request has been completed according to the instructions and that you have included the system/vault/group/project you need access to plus the role or permissions needed.
1. Most access requests need Manager approval so make sure to tag your manager in the AR and ask them to add the ~"AR-Approval::Manager Approved" and ~"ReadyForProvisioning" labels to the issue
1. Make sure you have tagged and assigned the issue to the correct provisioner(s) for the tool(s) you are requesting access to. You can find the provisioners for all our tools in our Tech Stack
1. If the provisioner is the IT team, please make sure to add the ~"IT::to do" label to the AR.
1. If you have followed all the steps above and your access request is still not being worked on, reach out to the team that owns the tools in their Slack channel. You can find the Slack Channel for each team in our Tech Stack

So you need access to a system or a group/vault?

1. Choose a template based on your needs: most people use the Bulk or Single Person template.
1. Do not open an Access Request for anything that is part of a baseline entitlement unless it got missed during onboarding.
 1. All team members baseline entitlements
 1. Role-based baseline entitlements
1. You must have the label AR-Approval::Manager Approved on the issue unless the person is:
 1. an internal team member being added to a Google Workspace email alias or group
 1. an internal team member being added to a slack group
 1. a completely unchanged role based baseline entitlement
1. Make sure to assign the issue to the people who provision access to the system.
1. If you need help, please ask IT-Ops in the slack channel it-help with a link to the issue you need help with.
1. Only ask for the least amount of access to do the work.

Do I need manager approval? Sometimes

You don't need manager approval if you are requesting the following:

1. An internal team member being added to a Google Workspace email alias or group (unless that group provides permissions to Google Cloud Platform)
1. An internal team member being added to a slack group
1. Something included in your role based entitlement

I need access to the Rails or database production console (grpd)

Please use Teleport to request temporary access to either the Rails console or the database console.

I need access to version.gitlab.com

You might already have it: Test if you have a dev account.

- If you need a dev account, open a Single Person Access Request.

- If you have a dev account, go to version and login with GitLab and authorize them to use your credentials.

I need access to Zendesk as a Light Agent

You don't need to open an access request for Zendesk light access. Follow the instructions to get access by email

I need to add an email alias, or name change

Please use the slackgooglegroup1password AR template for any email alias additions or name changes.

There are no restrictions on what can be requested, or how many, but please include a short explanation for the addition or change. Some alias requests may be denied if deemed inappropriate or at the discretion of operations.

While this application automation will take place in Okta, "true" system provisioning and deprovisioning will still need to be manually completed within the impacted systems via an Access Change Request.

Closing outdated access requests

It is expected that an access request will be completed as soon as possible (30 day's)

We have a pipeline setup that will automatically close access requests once they are past 30 days (at the time of creation).

This is to reduce stale AR's and clear out the backlog. The exception to this is if an AR has the AccessReview label, the pipeline will ignore the issue if it has that label.

This pipeline will add a comment on the issue that it is being automatically closed and what the team members should do if they have tasks remaining.

Currently, the pipeline is scheduled to be run at 09:30 PM on every Friday. It will close all access request issues that are 30 days old.

Please note: This is the first iteration of the AR auto closer. Our team will be working to refine and improve this.

I need to remove an existing access

Raise an Access Request specifying which accesses and person needs to be removed

SECTION: security/corporate/end-user-services/onboarding101/index.md

Welcome To GitLab

Congratulations on joining GitLab! This page is dedicated to the IT onboarding experience, here at GitLab we use many applications and the latest hardware to enable you to complete your work

to the best of your ability! While it may seem a little bit overwhelming at the start the Team member enablement team is here to make the process as easy as possible!

Laptop Setup: MacBook

> IMPORTANT: You will not have access to your work MacBook until your start date. On your start date, please follow this guide.

Before You Begin

You will receive an Okta activation email in your personal email. This is the first step to gaining access to GitLab's systems.

Step 1: Activate Your Okta Account

1. On a mobile device, check your personal email for an Okta activation email.
2. Click the link in the email to set your password
3. After setting your password, your browser will redirect to the Okta Dashboard. IMPORTANT: Do not open Gmail (G Suite SSO Mail) or any Google application (G Suite SSO Drive, G Suite SSO Calendar, G Suite SSO Account) before finishing the laptop setup process in Step 2. Opening these applications too early will lock you out of your laptop.
4. You will receive a follow-up email from Okta with the subject Security Method enrolled.

Step 2: MacBook Initial Setup

> IMPORTANT: If Remote Management is not available on your laptop, please use the Jamf MDM Setup Guide to manually enroll your device.

1. Power on your GitLab laptop
2. Complete the initial macOS setup:
 - Choose your preferred language
 - Select your country or region
 - Choose accessibility options (or click Not Now)
 - Select your WiFi network
 - On the Remote Management screen, click Enroll
3. Log into GitLab Okta:
 - Use the full GitLab email address (e.g., yourname@gitlab.com)
 - Enter the password you created on your personal device
 - Click Sign in
4. Set up your computer account:
 - Create a password for your local Mac account
 - Click Continue
5. Configure system settings:
 - On the Enable Location Services screen, check Enable Location Services on this Mac
 - Click Continue
 - On the Touch ID screen, click Continue
 - Enroll in Touch ID by placing your finger on the scanner (this is required)

- On the Choose Your Look screen, select Light, Dark, or Auto
- Click Continue

Step 3: System Configuration

1. On the Welcome to your new Mac! screen, wait while applications are automatically installed
 - This should take a few minutes
 - When finished, click Done
2. System Restart:
 - A pop-up will inform you that your machine needs to restart within the next minute
 - Wait for the automatic restart or initiate it yourself
 - After restart, log back in
3. Enable FileVault:
 - Click Enable Now when prompted to enable FileVault (disk encryption)

Step 4: Google Account Setup

1. Open Google Chrome
2. In the Sign in to Chrome window, click Sign in
3. Enter your GitLab email address
4. If Okta Verify opens, click Not now or close it
5. Sign in to Okta with your username and password
6. Click Agree on the Google Workspace policy that appears
7. On the Verify it's you screen, click Continue
8. On the Enhanced Ad Privacy in Chrome notice, click Got It
9. When you see Your organization will manage this profile, click Continue
10. On the Turn on Sync window, click Yes, I'm in

Step 5: Okta Account Verification

1. In Chrome, go to <https://gitlab.okta.com>
2. When Okta Verify appears:
 - On the Welcome to Okta Verify window, click Get Started
 - In Chrome, enter your Okta password and click Verify
 - In the Okta Verify window, click Enable for Enable Touch ID confirmation
 - Close the Complete tab in Chrome
3. Complete security verification:
 - In Chrome, click Verify it's you with a security method
 - Select Password and click Verify
 - In Okta Verify, click Yes, it's me (or provide your fingerprint)
4. Set up additional security methods:
 - On the Set up Security methods screen, click Set up for Security Key or Biometric authenticator
 - Click Set up again to confirm
 - On the Create a passkey for gitlab.okta.com pop-up, click Save another way
 - Select Your Chrome profile followed by Continue

Step 6: Access GitLab Email & GitLab.com Account

1. Access your GitLab email by clicking G Suite SSO Mail in Okta
2. Check your GitLab email for an email titled "Welcome to GitLab Onboarding, yourname!"
3. Follow the instructions in the email to set up your GitLab.com account and access your Onboarding Issue

Congratulations

You have completed the initial setup process for your GitLab account and MacBook. If you encounter any issues, please contact the IT Help Desk.

Laptop Setup: Linux

Step 1: Activate Your Okta Account

1. On a mobile device, check your personal email for an Okta activation email.
2. Click the link in the email to set your password
3. After setting your password, your browser will redirect to the Okta Dashboard
4. You will receive a follow-up email from Okta with the subject Security Method enrolled

Step 2: Okta Setup

1. On your Linux laptop, download Google Chrome
2. Open Google Chrome, and navigate to <https://gitlab.okta.com>
3. Complete security verification:
 - Click "Verify it's you with a security method"
 - Select "Password" and click "Verify"
4. Set up additional security methods:
 - On the "Set up Security methods" screen, click "Set up" for "Security Key or Biometric authenticator"
 - Click "Set up" again to confirm
 - On the "Create a passkey for gitlab.okta.com" pop-up, click "Continue"

Step 3: Google Account Setup

1. Access your GitLab email by clicking G Suite SSO Mail in Okta
2. In the Sign in to Chrome window, click Sign in
3. Enter your GitLab email address
4. Sign in to Okta with your username and password
5. Click Agree on the Google Workspace policy that appears
6. On the Verify it's you screen, click Continue
7. On the Enhanced Ad Privacy in Chrome notice, click Got It
8. When you see Your organization will manage this profile, click Continue
9. On the Turn on Sync window, click Yes, I'm in

Step 4: Access GitLab Email & GitLab.com Account

1. Check your GitLab email for an email titled "Welcome to GitLab Onboarding, yourname!"
2. Follow the instructions in the email to set up your GitLab.com account and access your

Onboarding Issue

Need Help?

If you need further assistance with setting up your laptop please join our weekly onboarding call scheduled every Tuesday (Check your Calendar!) or reach out to us in Slack in the ithelp channel.

SECTION: security/corporate/end-user-services/runbooks/template.md

> SOP - Standard operating process/procedure

Overview

> Intent of document

Provide a general overview of the tool, product, or what is being covered in this article. Include the scope of support and expectations.

Acronyms & Terminology

> break up the SOP into sections · install, location of info, how to use, best practice

Provide definitions for acronyms or common terms that may not be familiar to everyone. Include common search terms and phrases that may be used when looking for more information on this topic. You can use this as another section if you do not need an terminology section. (how to use, process section, common practices that you would like to capture and share with other team members.

Troubleshooting

Provide the problem or issue with the steps required to provide a solution. Include relevant screenshots, best practices, and tips. Include the escalation criteria, point of contact, and escalation procedures when troubleshooting has been exhausted.

- List Bullet 1
- List Bullet 2
- List Bullet 3

FAQs

Add any frequently asked questions and answers below.

Sample question 1

Sample answer 1

Sample question 2

Sample answer 2

Additional Information

This space is optional for any other details that are helpful to include.

Need Additional Help?

Area for more info

More Info

Metadata

Use this section to add common search terms for guidance. (add searchable metadata)

SECTION: security/corporate/engineering/_index.md

The Engineering team members are organized functionally based on the category of tech stack applications that we manage.

System Owners

```
<table>
<thead>
<tr>
<th>Functional Team</th>
<th>Systems</th>
<th>Managers</th>
<th>Engineers</th>
</tr>
</thead>
<tbody>
<tr>
<td><strong>(Corporate) SaaS<br>Engineering</strong></td>
<td>
<a href="/handbook/security/corporate/systems/1password">1Password</a><br>
<a href="/handbook/security/corporate/systems/gitlab">GitLab.com IAM Policies</a><br>
<a href="/handbook/security/corporate/systems/google/app">Google Apps</a><br>
<a href="/handbook/security/corporate/systems/google/cal">Google Calendar</a><br>
<a href="/handbook/security/corporate/systems/google/drive">Google Drive</a><br>
<a href="/handbook/security/corporate/systems/google/group">Google Groups</a><br>
<a href="/handbook/security/corporate/systems/google/mail">Google Mail</a><br>
<a href="/handbook/security/corporate/systems/google/user">Google Users</a><br>
<a href="/handbook/security/corporate/systems/google/workspace">Google Workspace (Org)</a><br>
<a href="/handbook/security/corporate/systems/nira">Nira</a><br>
<a href="/handbook/security/corporate/systems/okta/app">Okta Applications</a><br>
<a href="/handbook/security/corporate/systems/okta/group">Okta Groups</a><br>

```


[Okta Users](/handbook/security/corporate/systems/okta/user)

[Okta Workflows](/handbook/security/corporate/systems/okta/workflows)

Service Accounts

[Slack](/handbook/security/corporate/systems/slack)

[Zoom](/handbook/security/corporate/systems/zoom)

</td>
<td>
<code>EM</code> David Zhu

<code>EM</code> Eric Rubin

<code>PM</code> Kim Waters

<code>Staff</code> Mark Loveless
</td>
<td>
Clayton Shank

Erik Lentz

Jacob Waters

Justin Bisutti

Mohammed Al Kobaisy

Peter Hansen

Steve Ladgrove

Steve Sagan

Zack Hardie

</tr>
<tr>
<td>Device Trust
Engineering</td>
<td>
DriveStrike

Jamf MDM

Mobile Devices

NordLayer VPN

Okta Verify

SentinelOne EDR

Software Updates

YubiKey

</td>
<td>
<code>EM</code> Eric Rubin

<code>PM</code> Kim Waters

<code>Staff</code> Mark Loveless
</td>
<td>
Clayton Shank

Justin Bisutti

Zack Hardie

Peter Hansen

Steve Sagan

</tr>
<tr>

Identity Engineering	ABAC and RBAC AuthN and AuthZ Policies Identity Governance (IGA) No Code Automation Onboarding Offboarding Role Entitlements
EM David Zhu PM Kim Waters Staff Jeff Martin	Erik Lentz Jacob Waters Mohammed Al Kobaisy Steve Ladgrove
Infrastructure Engineering	Related Infrastructure Services
AWS Azure DNS Domain Names Google Cloud Tech Debt Cleanup Teleport Bastion	EM (Acting) Jeff Martin PM Kim Waters Staff Jeff Martin
Mohammed Al Kobaisy Vlad Stoianovici	
Platform Engineering (Self-Service Internal Provisioning Software)	

Related Demo Systems Related Sandbox Cloud
Access Check (accesschk) Access Control (accessctl) Demo Systems (gitlabdemo.com/cloud) HackyStack Provisionesta Open Source Packages Systems Administration Handbook Training Systems (trainingctl) (Corporate) Terraform Config Mgmt
Staff Jeff Martin
Jeff Martin AJ Romaniello (People Ops) Byron Boots (Sec Assurance) James Sandlin (Sec Assurance) Jacob Waters (CorpSec Identity) Logan Stucker (Demo) Scott Cosentino (Training)

SECTION: security/corporate/engineering/device-trust/_index.md

This is a placeholder page. Please see the links below for any child pages that exist.

SECTION: security/corporate/engineering/identity/_index.md

This is a placeholder page. Please see the links below for any child pages that exist.

SECTION: security/corporate/engineering/infrastructure/_index.md

This is a placeholder page. Please see the links below for any child pages that exist.

SECTION: security/corporate/engineering/platform/_index.md

This is a placeholder page. Please see the links below for any child pages that exist.

SECTION: security/corporate/engineering/saas/_index.md

This is a placeholder page. Please see the links below for any child pages that exist.

SECTION: security/corporate/how-we-work/_index.md

We have four approaches to how we work:

1. Support Helpdesk Services - We provide 24x5 technical support and access requests for team members and temporary service providers (contractors). Please help us prioritize your access request with corpsec-priority::ar-high (same/next day) or corpsec-priority::ar-low (same/next week) label.

2. Configuration Operations - We handle day-to-day small configuration and change requests (less than an hour) for configuring the SaaS systems that CorpSec is responsible for. This also includes escalations from our helpdesk analysts. Please create an issue in our issue tracker with your request and add the corpsec-priority::ops-high (same/next day) or corpsec-priority::ops-low (same/next week) label. You can ask for preliminary guidance in ithelp and our on-call team members will respond and/or tag an appropriate engineer.

3. Engineering Iterations - We have two week agile iteration sprint cycles for handling larger requests (more than an hour) that are queued up based on our team's capacity and competing priorities. This includes pre-planned implementation work related to other team's projects. When an issue is created, we will assign it a priority based on your due date requirements and add it to the backlog or schedule it during an upcoming iteration. Once an issue has been added to an iteration, you can expect it to be completed by the last day of the 2 week cycle unless communicated otherwise in the issue or in a discussion with the assigned engineer.

> Please create issues as far in advance as possible (3-6 weeks ideally, even as a draft) so it gets in the queue, rather than last minute requests that cause team members to scramble in a crisis mode. We are trying to avoid situations when your team knows about it for several months and ask us at the last minute to turn something around in a day or two with a deadline that could have been communicated several weeks in advance.

4. Engineering Initiatives - Larger program managed strategic initiatives on our roadmap that are part of our long term direction. We have objectives and key results (OKRs) that are aligned with the research, discovery, implementation, and migration to the new processes, services, systems. See our epics to see the current initiatives and progress.

Epics

All epics for larger initiatives and OKRs are created in the CorpSec group.

You can also view our gantt chart roadmap.

Issue Tracker

All issues are created in the CorpSec issue tracker for work that we have to either spend significant time performing or perform configuration and provisioning work that we need an easy-to-discover audit trail for. We can also be tagged in other team's issue trackers for consultative questions and support.

Workflow

mermaid
graph TD

```
subgraph "New Requests"
  OPENED["Issue Opened"]:::slate
  INBOX["<strong>corpsec-status::inbox</strong><br><strong>corpsec-  
priority::inbox</strong><br><strong>corpsec-  
metric::inbox</strong><br><strong>corpsys-{system}</strong><br><strong>corpsec-  
team-{team}</strong><br>Evaluated daily"]:::fuchsia
  AR["Access Request"]:::slate
  OPS["Day-to-Day<br>Config & Ops"]:::slate
  ENG["Engineering<br>Project<br>(2+ Hours)"]:::slate
  ARMETRIC["<strong>corpsec-metric::ar</strong>"]:::sky
  ARLOW["<strong>corpsec-priority::ar-low</strong><br>Resolved Same/Next Week"]:::emerald
  ARHIGH["<strong>corpsec-priority::ar-high</strong><br>Resolved Same/Next Day"]:::orange
  OPSMETRIC["<strong>corpsec-metric::ops</strong>"]:::sky
  OPSLOW["<strong>corpsec-priority::ops-low</strong><br>Resolved Same/Next Week"]:::emerald
  OPSHIGH["<strong>corpsec-priority::ops-high</strong><br>Resolved Same/Next Day"]:::orange
  TRIAGEMETRIC["<strong>corpsec-metric::triage</strong><br>Evaluated weekly"]:::sky
end

INITIATIVE["Initiative<br>Project Plan"]:::slate
INITIATIVEEPIC["Epic(s) Created"]:::slate
INITIATIVEISSUE["Issue(s) Created"]:::slate

WIP["<strong>corpsec-status::wip</strong>"]:::orange
REVIEW["<strong>corpsec-status::review</strong><br>Work is completed and<br>waiting on review  
or cleanup"]:::emerald
BLOCKED["<strong>corpsec-status::blocked</strong><br>Blocked for <br>technical reason"]:::red
WAITING["<strong>corpsec-status::waiting</strong><br>Waiting for business<br>or  
stakeholders"]:::violet
CLOSED["Issue Closed"]:::slate

subgraph "Sprint Planning"
  PRIORITIZE["<strong>Scoping and Prioritizing</strong><br>Evaluated bi-weekly"]
  METRIC["Metric"]:::sky
  WEIGHT["Weight"]:::fuchsia
```

BACKLOG["corpsec-status::backlog
Evaluated bi-weekly and
 scheduled for
2 week iteration
cycle based on re-prioritized
 or upcoming due date"]:::sky
SCHEDULED["corpsec-status::scheduled"]:::yellow
PZERO["corpsec-priority::p0
Imminent due date and
scheduled for current
or next
2 week iteration cycle"]:::red
PONE["corpsec-priority::p1
Project/task in the
next few weeks
 or
iteration cycles."]:::orange
PTWO["corpsec-priority::p2
Project/task in
this or next
quarter."]:::yellow
PTHREE["corpsec-priority::p3
Project/task in
the next year."]:::sky
PINITIATIVE["corpsec-priority::initiative
Prioritized based on
OKR,
timeline, or parent epic."]:::violet
end

OPENED --> INBOX
INBOX --> AR
INBOX --> OPS
INBOX --> ENG
AR --> ARMETRIC
ARMETRIC --> ARLOW
ARMETRIC ---> ARHIGH
OPS --> OPSMETRIC
OPSMETRIC --> OPSLOW
OPSMETRIC ---> OPSHIGH
ENG --> TRIAGEMETRIC
INITIATIVE --> INITIATIVEEPIC
INITIATIVEEPIC --> INITIATIVEISSUE
INITIATIVEISSUE ----> PINITIATIVE
TRIAGEMETRIC -----> PRIORITIZE

OPSHIGH ---> WIP
OPSLOW ----> WIP
ARHIGH ---> WIP
ARLOW ----> WIP

TRIAGEMETRIC -.-> PZERO
PZERO ---> SCHEDULED
METRIC -.- PRIORITIZE
WEIGHT -.- PRIORITIZE
PRIORITIZE --> PONE
PRIORITIZE --> PTWO
PRIORITIZE --> PTHREE
PONE ---> SCHEDULED
PTWO --> BACKLOG
PTHREE --> BACKLOG
PINITIATIVE --> BACKLOG
BACKLOG --> SCHEDULED
SCHEDULED ---> WIP
WIP <--> BLOCKED
WIP <--> WAITING

WIP --> REVIEW
REVIEW --> CLOSED

```
classDef slate fill:cbd5e1,stroke:475569,stroke-width:1px;
classDef red fill:fca5a5,stroke:dc2626,stroke-width:1px;
classDef orange fill:fdba74,stroke:ea580c,stroke-width:1px;
classDef yellow fill:fcd34d,stroke:ca8a04,stroke-width:1px;
classDef emerald fill:6ee7b7,stroke:059669,stroke-width:1px;
classDef cyan fill:67e8f9,stroke:0891b2,stroke-width:1px;
classDef sky fill:7dd3fc,stroke:0284c7,stroke-width:1px;
classDef violet fill:c4b5fd,stroke:7c3aed,stroke-width:1px;
classDef fuchsia fill:f0abfc,stroke:c026d3,stroke-width:1px;
```

Iteration Cadences

We perform sprint planning on a weekly or bi-weekly basis (depending on system/team) and evaluate issues with the corpsec-status::inbox and corpsec-status::backlog label.

See the Workflow to see the full flow of issues.

- Cadence Schedule

Due Dates

Due dates are the date set by the requester.

Iteration cycles are used by the CorpSec team internally.

Any expectations should be mentioned in the issue description or comments so the work is completed in an iteration cycle that ends before your due date.

Issue Boards and Lists

Helpdesk Analysts

- (List) Access Requests
- (List) Baseline Entitlements to Provision
- (List) Team Member Access Requests
- (List) Temporary Service Provider Access Requests

Engineering

- (Report) Management Status Report (Updated Daily)
- Kanban Board
 - (Board) All Teams - Current Iteration - Iteration Sprint Issues (by Status)
 - (Board) Code - Current Iteration - All Open Issues
 - (Board) Device Trust - Current Iteration - All Open Issues
 - (Board) Helpdesk - All Open Issues
 - (Board) Identity - Current Iteration - All Open Issues

- (Board) Infrastructure - Current Iteration - All Open Issues
- (Board) SaaS - Current Iteration - All Open Issues
- Issue Lists by Team
 - (List) Small Day-to-Day Operations Requests
 - (List) Larger Project Work (Device Trust, Identity, and SaaS Engineering)
 - (List) Internal Issues for Code Platform Engineering / Open Source Issues
 - (List) Issues for Device Trust Engineering
 - (List) Issues for Helpdesk Services
 - (List) Issues for Infrastructure Engineering
 - (List) Issues for SaaS Engineering
- Issue Lists by Status
 - (List) Inbox Requests (Reviewed Daily)
 - (List) Triage in Progress (reviewed bi-weekly)
 - (List) Backlog
 - (List) Scheduled
 - (List) Work in Progress (WIP)
 - (List) Waiting for Business
 - (List) Technically Blocked
 - (List) Final Review
- (List) See CorpSec Systems handbook page for links to issues for specific systems.

Engineering Team Members

Team Member	CorpSec Issues	Assigned ARs	Handbook MRs
Clayton Shank	Issues - Kanban - Current Iteration	ARs	Public - Internal

David Zhu	Issues - Kanban - Current Iteration
ARs	Public - Internal
Eric Rubin	Issues - Kanban - Current Iteration
ARs	Public - Internal
Erik Lentz	Issues - Kanban - Current Iteration
ARs	Public - Internal
Jacob Waters	Issues - Kanban - Current Iteration
ARs	Public - Internal

tracker/-/issues/?assigneeusername%5B%5D=jacobdwaters">Issues - Kanban - Current Iteration</td>
<td>ARs</td>
<td>Public - Internal</td>
</tr>
<tr>
<td>Jeff Martin</td>
<td>Issues - Kanban - Current Iteration</td>
<td>ARs</td>
<td>Public - Internal</td>
</tr>
<tr>
<td>Justin Bisutti</td>
<td>Issues - Kanban - Current Iteration</td>
<td>ARs</td>
<td>Public - Internal</td>
</tr>
<tr>
<td>Kim Waters</td>
<td>Issues - <a target="blank" href="https://gitlab.com/groups/gitlab-com/gl-

security/corp/-/boards/7606111?assigneeusername=kimwaters">Kanban - Current Iteration</td>

<td>ARs</td>

<td>Public - Internal</td>

</tr>

<tr>

<td>Mark Loveless</td>

<td>Issues - Kanban - Current Iteration</td>

<td>ARs</td>

<td>Public - Internal</td>

</tr>

<tr>

<td>Mohammed Al Kobaisy</td>

<td>Issues - Kanban - Current Iteration</td>

<td>ARs</td>

<td>Public - Internal</td>

</tr>

<tr>

<td>Peter Hansen</td>

<td>Issues - Kanban - <a target="blank" href="https://gitlab.com/groups/gitlab-com/gl-security/corp/-

/boards/7606111?assigneeusername=phan&iterationid=Current&iterationcadenceid=1053644">Current Iteration</td>

<td>ARs</td>

<td>Public - Internal</td>

</tr>

<tr>

<td>Steve Sagan</td>

<td>Issues - Kanban - Current Iteration</td>

<td>ARs</td>

<td>Public - Internal</td>

</tr>

<tr>

<td>Vlad Stoianovici</td>

<td>Issues - Kanban - Current Iteration</td>

<td>ARs</td>

<td>Public - Internal</td>

</tr>

<tr>

<td>Zack Hardie</td>

<td>Issues - Kanban - Current Iteration</td>

ARs	Public	Internal
---	---	--

Time Tracking

When issues are prioritized and scheduled to be worked on, they can optionally have a time estimate added (in hours) using `/estimate {h}`. This allows the engineer to be a manager of one and work on the issue however they see fit by the iteration end date.

As engineers work on issues, they can optionally add `/spent {1.5}h` to keep track of their progress. This is optional has two benefits:

1. It allows the engineer to validate whether the time estimate was accurate.
2. It surfaces to the management team how much work was put into the issue.

Any issue that an engineer adds a time spent to will automatically show up on management and team status reports with the title and time spent. Any issue without a time spent will show up on status reports with the count of issues worked on in a specific project. A best practice is that if it takes more than 30-60 minutes, you should consider adding time spent. If something is important that should appear on a status report, then even a 5 minutes of time spent can be added.

See weight as an alternative to time tracking.

Weight

Some engineers do not like tracking their time and just see the list of issues to work on.

Instead of time tracking, you can add a weight to share how difficult it was to work on. Weights are also used during sprint planning.

1 weight is equal to roughly a half day of work (ex. a 3-4 hour focus block).

Any issue that an engineer adds a weight to will automatically show up on management and team status reports with the title and weight along with a time estimate if it was set. Any issue without a weight will show up on status reports with the count of issues worked on in a specific project. A best practice is that if it takes more than an hour or two, you should consider adding a weight.

Labels

Status Label

- corpsec-status::inbox - This issue is new and has not been evaluated yet. (default for new issues).
- corpsec-status::wishlist - For any issues not being worked on in the next year or become dormant. Stale issues can be closed and can be reopened if priority changes.
- corpsec-status::backlog - This issue is in our backlog to be completed within a year (see priority).
- corpsec-status::waiting - This issue has started but is on hold waiting for a business reason or review.
- corpsec-status::blocked - This issue has started but is blocked for a technical reason that is not anticipated to be solved during this iteration.
- corpsec-status::scheduled - This issue has been scheduled to be worked on in an upcoming iteration milestone.
- corpsec-status::wip - This issue is a work in progress. The team member will assign this status when they pick it up.
- corpsec-status::review - The work is mostly complete and is waiting on final review or cleanup work.

Priority Label

- corpsec-priority::inbox - Needs triage to determine (default for new issues).
- Business as Usual Day-to-Day Requests
 - corpsec-priority::ar-high - High priority (same day) access